



File No.: EXP202315693 (PA/00060/2023)

RESOLUTION OF

PROCEEDING OF WARNING

From the proceeding initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on February 18, 2022. The complaint is directed against AXA SEGUROS GENERALES S.A. DE SEGUROS Y REASEGUROS with NIF A60917978 (hereinafter, AXA SEGUROS). The reasons for the complaint are as follows:

Complaint against DIRECT SEGUROS regarding the use of cookies on its website. The complainant argues that cookies are loaded "before being able to manage them, without taking any action" and that, concerning the use of Google Analytics, international transfers to the U.S. are occurring.

Along with the complaint, the following documents were submitted:

- Printout of the website <https://www.directseguros.es/>
- Printout from the Chrome browser – Settings - Security and Privacy.

On March 18, 2022, the following evidence collected by this Agency was added to the file:

- Cookie policy of www.directseguros.es, which lists the following Google Analytics cookies as statistical cookies: `_ga`, `_gid`. A test of installed cookies after acceptance confirmed the installation of the mentioned Google Analytics cookies.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGD), the complaint was forwarded to the defendant party for analysis and to inform this Agency within one month of the actions taken to comply with the requirements established in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on May 5, 2022, as noted in the acknowledgment of receipt in the file.

On June 2, 2022, this Agency received a response indicating that:

"1. Report on the causes that led to the incident that originated the complaint.

FIRST. – AXA has a cookie manager or CMP on its website [directseguros.es](https://www.directseguros.es/), a tool provided by the supplier Cookiebot, as well as direct and permanent access to the Cookie Policy in a section provided for this purpose at the bottom of the website. After conducting explicit tests to respond to this request, no incidents in the operation of the cookie manager were found.

SECOND. - No evidence is provided in the complaint that substantiates the described incident, and after reviewing the website, it is confirmed that the operation complies with the legal obligations in force regarding cookies.

On the other hand, AXA has sufficient evidence demonstrating compliance with all requirements for the installation of cookies under current regulations, as stated in this document. (Document 1 includes screenshots of the cookie acceptance banner from Direct Seguros).

2. Report, if applicable, on the measures taken to adapt its "Privacy Policy" to Article 13 of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016 (GDPR), implementation dates, and controls carried out to verify its effectiveness.

THIRD. - AXA has the Privacy Policy at the bottom of its website, accessible at any time for users of the website. The Privacy Policy of Direct Seguros includes all data processing carried out according to the type of interested party and in accordance with the sections of Article 13 of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016 (GDPR). The Privacy Policy of the direct seguros website can be consulted at the following address:

<https://www.directseguros.es/privacidad.html>

3. Report, if applicable, on the measures taken to adapt the use of cookies to the provisions of Article 22.2 of Law 34/2002, of July 11, on Information Society Services and Electronic Commerce (LSSI),

particularly regarding the information provided to users about the use of cookies and the purposes of data processing, as well as the way to collect, reject, or withdraw consent for their use. Indication of implementation dates and controls carried out to verify its effectiveness is also requested.

FOURTH. – AXA has implemented the Cookiebot cookie manager on the Direct Seguros website, which is activated when the user accesses its website, allowing visiting users to select and accept non-technical cookies (statistical, marketing, and preference cookies) before their installation, collecting the...

3/30

user consent on the website for each of the types of cookies that require consent, and providing the possibility to modify or revoke the consent previously granted at any time, from the clearly identified section in AXA's Cookie Policy.

FIFTH. - In this cookie manager, as well as in the Cookie Policy in compliance with current regulations, information is provided for each cookie regarding: the name of the cookie, the provider, the purpose for which the cookie is installed, the type, and its duration.

It is also indicated that by clicking "Save selection," the cookies that the user has previously selected will be saved. If no option is selected, clicking that button is equivalent to rejecting all cookies.

In short, this cookie manager complies with the obligations established by the applicable regulations, ensuring that non-technical cookies are not installed without the user's prior consent.

(Document 2: Screenshot of the cookie banner and installed technical cookies is provided.)

SIXTH. - In section 3 of the Cookie Policy, the method to revoke consent or delete cookies is described. Furthermore, in section 5 of this Cookie Policy, AXA provides direct access to change or withdraw the consent previously granted by the user. The Cookie Policy of the Direct Seguros website can be consulted at the following address:

<https://www.directseguros.es/cookies.html>

(Document 3: Screenshot of the section of the Cookie Policy to modify or revoke the consent granted by the user is provided.)

SEVENTH. - AXA has verified that the cookies installed prior to obtaining consent are technical cookies necessary for the operation of the website and the cookie manager. There is no record of non-technical cookies being installed without obtaining the user's consent through the cookie manager.

EIGHTH. - AXA, as an internal control system, has an internal cookie governance committee formed by the different areas involved in the management, installation, and analysis of cookies by AXA and by the Data Protection Officer team of the Company.

This Committee meets periodically to review the current inventory of cookies, the need to include or remove any of the existing ones, as well as to analyze any new cookies to be installed and verify the correct functioning to monitor the tool.

As a result, the inventory of cookies used on the website is regularly updated according to business needs and what is agreed upon in the Internal Committee at each moment. This implies that this inventory may vary from the date AXA submits this response to this Agency.

4. The decision made regarding this complaint.

NINTH. - Following this complaint, AXA has proceeded to review and conduct control tests within AXA's internal control process regarding cookies, which has confirmed that there is no incident in the cookie manager nor in those actions that allow granting, modifying, or withdrawing consent on the website <https://www.directseguros.es/>, resulting in the certainty of the correct functioning of the cookie manager tool.

THIRD: On May 19, 2022, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: On May 28, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate a warning procedure against the respondent for the alleged infringement of Article 44 of the GDPR, classified under Article 83.5 of the GDPR.

FIFTH: The notification of the aforementioned initiation agreement, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was received on May 29, 2024, as recorded in the acknowledgment of receipt in the file.

SIXTH: On May 30, 2024, AXA SEGUROS submitted a document requesting an extension of the deadline to present allegations.

SEVENTH: On June 7, 2024, the instructing body of the procedure agreed to extend the requested deadline by a maximum of five days, in accordance with the provisions of Article 32.1 of the LPACAP. The aforementioned agreement was notified to AXA SEGUROS on June 7, 2024, as recorded in the acknowledgment of receipt in the file.

EIGHTH: On June 19, 2024, a document of allegations was received from the respondent, which, in summary, includes the following considerations:

- AXA SEGUROS has followed the indications made by the CEPD in Recommendations 01/2020, taking as a reference the draft version published before its final approval on June 18, 2021, in order to ensure that any potential international data transfers comply with the guarantees required by the European authority as soon as possible, even adopting them before they were definitively approved in June 2021.

Additionally, it lists a series of complementary measures such as the management of IPs, the User ID functionality, and personal data collected through the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/30

implementation (quote_id), in order to try to guarantee a level of protection equivalent to that established in the GDPR for those data transferred to the U.S.

- From the date of the claim in question until the present request, there is no record of any request for information disclosure by U.S. public entities that would imply an international data transfer to this country.

In light of all the actions taken, the following facts are considered proven by the Spanish Agency for Data Protection in this procedure:

PROVEN FACTS

FIRST: On March 18, 2022, in connection with the analysis of the claim filed by the claimant against AXA SEGUROS, this Agency confirms that the cookie policy of www.directseguros.es includes the following Google Analytics cookies as statistical cookies: _ga, _gid. (page 22 of the file). The purpose of these cookies according to AXA SEGUROS' cookie policy is as follows:

- “- _ga: Records a unique identifier used to generate statistical data about how the visitor uses the website.

- _gid: Records a unique identifier used to generate statistical data about how the visitor uses the website.”

(the underlining is ours)

On that same date, the following action was taken: acceptance of the cookies from the website www.directseguros.es through the Chrome browser. The image included in the file confirms that the cookies _ga, _gid have been installed (page 29 of the file).

SECOND: On June 19, 2024, in the allegations to the initiation agreement of the present procedure, AXA SEGUROS acknowledges that it has introduced the code of the Google Analytics tool on its website: “...The following are the complementary measures that were implemented by AXA, regarding the Google Analytics services related to the website www.directseguros.es, concerning the present sanctioning file.”

THIRD: On September 2, 2020, the plenary of the European Data Protection Committee decided to create a working group (hereinafter, working group TF101) to ensure a coherent approach among European data authorities regarding the management of the 101 complaints from NOYB related to the use of Google Analytics and the possible data transfers to the U.S., in the context of the CJEU ruling Schrems II.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

6/30

FOURTH: In the document dated April 9, 2021, sent by GOOGLE LLC to the Austrian data protection authority, which shares it with the rest of the authorities through the TF101 working group regarding NOYB complaints in the context of the CJEU ruling Schrems II, the following information and statements are recorded (from its unofficial translation from English):

1.

(...):

a.

(...):

i.

(...).

(...).

ii.

(...).

iii.

(...).

2.

(...):

(...)

(...)

(...).

3.

(...).

4.

(...):

a.

(...).

b.

(...).

5.

(...).

6.

(...).

7.

(...).

8.

(...).

9.

(...):

a.

(...)

b.

(...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/30

c.

(...).

d.

(...).

10.

(...):

a.

(...).

i.

(...).

ii.

(...).

b.

(...).

c.

(...).

d.

(...).

11.

(...):

a.

(...).

b.

(...).

c.

(...)

FIFTH: In the model of the Adhesion Contract to GOOGLE services (page 145 and following of the file), titled "Terms of Data Processing of Google Ads"

(<https://privacy.google.com/businesses/processorterms/>), in its version of September 21, 2022, it stated that (unofficial translation):

"Terms of Data Processing of Google Ads

Google and the counterparty accepting these Conditions (the "Client"), have entered into a contract for the provision of the Services of the data processor (with its specific amendments, the "Contract")

These Conditions of data processing of Google Ads (the "Data Processing Conditions") are subscribed by Google and the Client and complement the Contract.

[...]

If you accept these Terms of Data Processing on behalf of the Client, you warrant that a) you have full legal authority for these Terms of Data Processing to be binding on the Client, b) you have read and understand these Terms of Data Processing, and c) you accept them on behalf of the Client. If you do not have the legal authority for these Terms of Data Processing to be binding on the Client, do not accept them.

Introduction

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/30

These Data Processing Terms reflect the agreement between the parties regarding the terms governing the processing of certain data in relation to European Data Protection Legislation and certain Non-European Data Protection Legislation.

Definitions and interpretation

[...]

"Google Entity" refers to Google LLC (formerly known as Google Inc.), Google Ireland Limited, or any other entity that, directly or indirectly, controls Google LLC, is controlled by Google LLC, or is under the same control as Google LLC.

"Google" refers to the Google Entity that is a party to the Contract.

“European Data Protection Legislation” refers, as applicable, to a) the GDPR and/or b) the FDPA of Switzerland.

[...]

“SCCs” refers to the Customer Standard Contractual Clauses and/or the Standard Contractual Clauses (Processor to Processor, Google Exporter), as applicable.

[...]

“SCCs (Processor to Processor, Google Exporter)” refers to the terms included in business.safety.google/adsprocessors/terms/sccs/p2p-intra-group.

[...]

“Sub-processors” refers to third parties authorized under these Data Processing Terms to have logical access to the Customer's Personal Data and process it for the purpose of providing part of the Processor's Services and any related technical assistance.

[...]

5. Data Processing

5.1 Roles and compliance; authorization.

5.1.1 Responsibilities of the Data Processor and the Data Controller.

The parties acknowledge and agree to the following:

(a) Appendix 1 describes the issue and details of the processing of the Customer's Personal Data.

(b) Google is a processor of the Customer's personal data;

(c) The Customer is a data controller or a processor, as applicable, of the Customer's Personal Data; and

(d) Each party will fulfill its respective obligations under the Applicable Data Protection Legislation with respect to the processing of the Customer's Personal Data.

[...]

5.2 Customer Instructions. By entering into these Data Processing Terms, the Customer instructs Google to process the Customer's Personal Data only in accordance with applicable law: a) to provide the Processor's Services and any related technical assistance, b) as specified in more detail through the Customer's use of the Processor's Services (including the configuration and other features of the Processor's Services) and any related technical assistance, c) as documented through the Contract (including these Data Processing Terms), and d) as documented in more detail in other instructions provided in writing by the Customer and acknowledged by Google as constitutive instructions for the purposes of these Data Processing Terms (collectively, the “Instructions”).

5.3 Compliance with Instructions by Google. Google will comply with the Instructions unless prohibited by Applicable Laws or such Applicable Laws require different processing.

[...]

10. Data Transfers

10.1 Data storage and processing facilities. In accordance with this section 10 (Data Transfers), Google may process the Customer's Personal Data in any country where Google or any of its Sub-processors has facilities.

10.2 Restricted European Transfers. The parties acknowledge that European Data Protection Legislation does not require SCCs or an Alternative Transfer Solution to process the Customer's Personal Data in an Adequate Country or to transfer it to such a country. If the Customer's Personal Data is transferred to any other country and such transfers are subject to European Data Protection Legislation (“...”), then:

If Google adopts an Alternative Transfer Solution for any Restricted European Transfer, Google will inform the Customer of the relevant solution and ensure that such Restricted European Transfers are carried out in accordance with such Solution and/or If Google has not adopted or has informed the Customer that it will no longer adopt any Alternative Transfer Solution for any Restricted European Transfer, then:

If Google's address is in an Adequate Country:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/30

The SCCs of the Data Processor will apply to the Data Processor, Google Exporter, regarding all Restricted European Transfers from Google to the Sub-Processors.

(B) Furthermore, if the Client's address is not located in an Adequate Country, the SCCs (Data Processor to Data Controller) will apply regarding the Restricted European Transfers between Google and the Client, regardless of whether the Client is a data controller and/or a data processor or (ii) If Google's address is not located in an Adequate Country, the SCCs of the Data Controller to the Data Processor and/or the SCCs (Data Processor to Data Processor) will apply, depending on whether the Client is a data controller and/or a data processor, regarding the Restricted European Transfers between the Client and Google.

10.3 Complementary measures and information. Google will provide the Client with relevant information regarding the Restricted European Transfers, including information on complementary measures to protect the Client's Personal Data, as described in section 7.5.1 (Security Documentation Reviews), in appendix 2 (Security Measures), and in other materials related to the nature of the Data Processor Services and the processing of the Client's Personal Data (e.g., articles from the help center).

10.4 Termination. If the Client concludes, based on the use they make or intend to make of the Data Processor Services, that the Alternative Transfer Solution and/or the SCCs, as applicable, do not provide adequate protection for the Client's Personal Data, the Client may immediately terminate the Contract for convenience by providing written notice to Google.

10.5 Data center information. Information about the locations of Google's data centers is available at www.google.com/about/datacenters/locations/.

11. Sub-Processors.

11.1 Consent for engaging a Sub-Processor. The Client specifically authorizes the engagement of the entities listed, as of the Effective Date of the Terms, at the URL specified in section 11.2 (Information about Sub-Processors). Furthermore, and without prejudice to the provisions of section 11.4 (Opportunity to oppose changes of the Sub-Processor), the Client generally authorizes the engagement of any other third party as a Sub-Processor ("New Sub-Processors").

[...]" (the underlining is ours).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/30

SIXTH: In the description of Google Analytics, available at the URLs

<https://developers.google.com/analytics/devguides/collection/analyticsjs/field-reference> and

<https://developers.google.com/analytics/devguides/collection/gajs/cookie-usage>, it was stated, among other information, that the cookies `_ga` and `_gid` were used to distinguish users and that the parameter "sr" referred to screen resolution (page 136 and following of the file).

SEVENTH: According to the response to question 4 (ii) of the document dated April 9, 2021, from GOOGLE LLC in the file, the owner of the website that has implemented the Google Analytics code on that website can choose from multiple retention periods ranging from 2 months to 50 months from the time the data was collected.

EIGHTH: According to the diligence dated September 27, 2024, in the file, on January 18, 2021, at the URL <https://policies.google.com/terms/information-requests?hl=en-US> it stated (unofficial translation, original in English):

"[...]"

Requests from U.S. government agencies in cases involving national security

In investigations related to national security, the U.S. government may use a National Security Letter (NSL) or one of the authorizations granted under the Foreign Intelligence Surveillance Act (FISA) to compel Google to provide user information.

An NSL does not require judicial authorization and can only be used to compel us to provide limited subscriber information.

FISA orders and authorizations can be used to compel electronic surveillance and the disclosure of stored data, including the content of services such as Gmail, Drive, and Photos.”

[...]” (unofficial translation, original in English)

NINTH: According to the diligence dated September 27, 2024, in the file, on January 26, 2022, at the URL <https://support.google.com/analytics/answer/7686480> it stated (unofficial translation, original in English):

“[...]

Basics about personally identifiable information in Google contracts and policies.

In many contracts, terms of service, and policies for Google’s advertising and measurement products, reference is made to “personally identifiable information” (PII).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/30

This is a categorization of data different from what the General Data Protection Regulation (GDPR) considers “personal data.”

Please note that, although Google does not identify certain data as personally identifiable information, it is possible that the GDPR does or that such data may be considered personal information under the California Consumer Privacy Act (CCPA), and may be subject to those laws.

[...]

Google considers “personally identifiable information” to be information that can be used alone to identify or locate a person accurately, or to contact them directly. Among other data, it includes the following:

- Email addresses
- Postal addresses
- Phone numbers
- Precise locations (e.g., GPS coordinates, except in the cases mentioned below)
- Full names (first and last name) or usernames.

[...]

Among others, Google does not consider the following data to be personally identifiable information:

- Pseudonymous cookie IDs
- Pseudonymous advertising IDs
- IP addresses
- Other pseudonymous end-user identifiers

For example, if an IP address is sent with an ad request (something that happens with almost all ad requests as a result of Internet protocols), that submission will not violate any prohibition related to sending personally identifiable information to Google.

Please note that, although Google does not identify certain data as personally identifiable information, it is possible that the GDPR, the CCPA, or other privacy laws may consider them personal data or personal information.

[...]

TENTH: As stated in the diligence dated September 27, 2024, in the file, at the URL

<https://transparencyreport.google.com/user-data/us-national-security?hl=en>, Google has been publishing since 2009 the number of requests for user information in the U.S. related to FISA (Foreign Intelligence Surveillance Act) and NSL (National Security Letters).

LEGAL GROUNDS

I

Competence and procedure

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47,

48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued in its development, and, to the extent that they do not contradict them, by the general rules on administrative procedures in a subsidiary manner."

Considering the nature of the facts that have led to the proceedings and the concurrent circumstances, this warning procedure is being conducted in accordance with the provisions of Article 64.3 of the LOPDGDD.

II

Preliminary issues

Article 4.2 of the GDPR defines "processing" as:

"any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or any other form of enabling access, alignment, combination, restriction, erasure or destruction."

For its part, Article 4.7 of the GDPR defines the "data controller" or "controller" as:

"the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of the processing, the controller or the specific criteria for its designation may be provided for by the law of the Union or of the Member States."

In this case, according to the provisions of Articles 4.1 and 4.2 of the GDPR, there is evidence of the processing of personal data, since AXA SEGUROS collects and processes, through the Google Analytics service, among other data, the following personal data of natural persons: unique user identifiers (_ga and _gid), the IP address, as well as other data associated with the browser and the browsing itself, among other processes.

AXA SEGUROS carries out this activity in its capacity as data controller, as it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR.

Article 44 of the GDPR regulates the transfer of personal data to

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/30

third countries.

III

Response to the allegations

Below, we proceed to respond to the allegations presented by the responding entity, in the order in which they are formulated in their writing:

"FIRST – REGULATION OF INTERNATIONAL DATA TRANSFERS"

According to AXA SEGUROS: "In the specific case of the services provided by the supplier subject to this procedure, the Responding Party strictly followed the indications made by the EDPB in Recommendations 01/2020, using the draft version published prior to its final approval on June 18, 2021, as a reference, in order to ensure that any potential international data transfers complied with the guarantees required by the European authority as soon as possible, even adopting them before they were definitively approved in June 2021."

Regarding the regulations in force at the time of the transfers: "AXA conducted a detailed analysis of the local legislation of the U.S., in order to assess whether the supplier subject to this procedure, as a provider located in the U.S., would have the capacity to comply with the contractual obligations subscribed with AXA regarding the processing of data in this procedure, or if there would be any limitations arising from its national regulations.

In this regard, it is stated that the supplier could comply with the stipulated measures and achieve an

adequate level of protection, considering the possibility of access by U.S. public authorities as residual and not sufficient to conclude that the contractually assumed guarantees would not be met.” Subsequently, AXA SEGUROS enumerates a series of complementary measures such as the management of IPs, the User ID functionality, and personal data collected through the implementation (quote_id), in order to try to ensure a level of protection equivalent to that established in the GDPR for those data transferred to the U.S.

In response to these arguments, first, regarding the measures adopted under Recommendations 01/2020, concerning measures that complement transfer instruments to ensure compliance with the level of protection of EU personal data, they cannot enable standard contractual clauses as an adequate means for making international data transfers to the U.S. since the CJEU stated in case C-311/18 ("Schrems II") that their use could not alone guarantee a level of protection, as required by Article 44 of the GDPR, as it could not prevent the possibilities of access by U.S. services.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/30

of U.S. intelligence to the transferred data. Given that the contractual nature of these clauses derived from the fact that they could not be binding for the authorities of third countries. In particular, the CJEU stated that: “...Therefore, while there are situations in which, depending on the legislation and practices in force in the third country in question, the recipient of such a transfer is able to guarantee the necessary protection of the data solely on the basis of standard contractual clauses for data protection, there are others in which the content of such standard clauses may not constitute a sufficient means to ensure, in practice, the effective protection of the personal data transferred to the third country in question. This is particularly the case when the legislation of that third country allows its public authorities to interfere with the rights of the data subjects to whom the data refers” (C-311/18, paragraph 126, emphasis added).

Therefore, regarding the supplementary measures adopted by AXA SEGUROS, it is true that this type of technical measures did not prevent or reduce the possibilities of access by U.S. intelligence services based on the legal framework of the United States.

Furthermore, the following comments can be made regarding the stated measures:

“▪ IP Management:”

This configuration option in IP management does not prevent their collection, which in itself constitutes the processing of personal data of the data subjects, regardless of subsequent anonymization. For example, in Google Analytics 4, according to Google’s “Privacy and Data in the EU” (https://support.google.com/analytics/answer/12017362?hl=en&ref:_topic=2919631), “...IP address data is used solely to obtain geolocation data and is discarded immediately,” so information that can be provided by the IP is used before anonymization. The act of collecting the IP itself constitutes a processing operation.

“▪ User ID: unique user identifier.”

While the use of the User ID functionality may increase the possibilities of identifying users by being able to associate their own identifiers with individual users so that their behavior can be connected across different sessions and various devices and platforms; the lack of use of this functionality does not prevent users of the website www.directseguros.es from being identifiable through the combination of unique identifiers with other elements, as reasoned in point 2 of the Legal Basis IV of this resolution. In this way, other data such as IP or information stored in cookies can commonly be used to identify a user, especially when combined with other similar types of information. This is illustrated in Recital 30 of the GDPR, according to which the assignment of online identifiers such as IP addresses and cookie identifiers to natural persons or their devices can “leave traces that, particularly when combined with unique identifiers and other information received by servers, can be used to create profiles of natural persons and identify them.”

C/ Jorge Juan, 6

www.aepd.es

As an example, let us recall the functions that, as described in the Established Facts, are attributed to the cookies `_ga` and `_gid`. The cookie `_ga` records a unique identifier that is used to generate statistical data about how the visitor uses the website, and the cookie `_gid` records a unique identifier that is used to generate statistical data about how the visitor uses the website.

“▪ Personal data collected through the implementation (`quote_id`): personal data collected for analytical purposes:”

The encryption of the budget numbers generated in all insurance quotes made on www.directseguros.es may be a technique for enhancing privacy, but, as previously stated, it does not prevent the possibilities of access by U.S. intelligence services nor does it render such access ineffective.

While pseudonymization may be a technique for enhancing privacy, unique identifiers have, as previously described, the specific intention of selecting users, not of acting as a safeguard. Apart from this, it has also been previously described why the combination of unique identifiers with other elements (such as browser or device data and the IP address) and the possibility of linking such information to a Google account in any case allows an individual to be identified.

For all these reasons, this allegation is dismissed.

“SECOND. – ON INTERNATIONAL TRANSFER”

In this allegation, AXA SEGUROS argues that “from the date of this claim until the present request, there is no record of any request for information disclosure by U.S. public entities, which would imply an international transfer of data to this country.”

In response to this assertion, it should be noted that Google does not always notify its users of information requests. On Google’s website, which informs about “How Google handles government requests for user information,” it states: “We do not send any notification to the user in cases where it is prohibited by law according to the terms of the request. However, such notification is sent once the corresponding legal prohibition is lifted, such as when a court-ordered gag order has expired.”

Moreover, the fact that, as AXA SEGUROS claims, there has been no access to the data collected on the website www.directseguros.es, that is, that the risk of access to the data transferred without the guarantees established in the GDPR has not materialized, does not prevent the international transfer of data from being contrary to the GDPR. From the reading of the access statistics data referred to in Established Fact Nine, it can be verified that access by U.S. intelligence agencies to the personal data collected by Google represented a real risk.

For all the above reasons, this allegation is dismissed.

IV

Transfers of personal data to third countries

Article 44 “Transfers of personal data to third countries or international organizations” of the GDPR establishes:

“Personal data that are subject to processing or will be processed after their transfer to a third country or international organization may only be transferred if, subject to the other provisions of this Regulation, the controller and the processor comply with the conditions established in this chapter, including those relating to further transfers of personal data from the third country or international organization to another third country or another international organization. All provisions of this chapter shall apply in order to ensure that the level of protection of natural persons guaranteed by this Regulation is not undermined.”

Chapter V of the Regulation provides various instruments to ensure a level of protection substantially equivalent to that guaranteed in the European Union, in accordance with Article 44 of the Regulation:

- adequacy decisions (Article 45);
- appropriate safeguards (Article 46);

In the absence of an equivalent level of protection, it establishes exceptions for specific situations (Article 49).

1.

On the processing of data and the responsibility for processing.

In the document dated April 9, 2021, sent by Google LLC to the Austrian data protection authority, which it shared with the other authorities within the framework of the TF101 working group, it is indicated that Google Analytics operates by including a block of Javascript code on the pages of a website. When a user visits a webpage, this Javascript code refers to a Javascript code that has been previously downloaded to the user's device, which then executes the tracking operation for Google Analytics. The tracking operation sends data about the requested page through various means and sends this information to the Analytics server via a series of parameters attached to a request for a single pixel GIF image sent to the domain google-analytics.com. The data is then processed more extensively and ends up in the reports of the website owner, in this case, AXA SEGUROS. The data that Google Analytics collects on behalf of the website owner comes from the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/30

following sources:

i.

The user's HTTP request.

An HTTP request contains details such as the browser and the computer making the request, such as the hostname, browser type, 'referrer', and language.

ii.

Browser and system information.

iii.

First-party cookies.

Website administrators who integrate the Google Analytics service can send instructions to Google for processing the data collected through Google Analytics. The website administrator can apply different settings, for example, regarding the data retention period. The Google Analytics function also allows website administrators to monitor and maintain the stability of their website, for example, keeping them informed of certain events such as a spike in audience or the fact that there is no traffic at all. Google Analytics also allows website administrators to measure and optimize the effectiveness of advertising campaigns conducted using other Google tools.

Therefore, Google Analytics collects the user's HTTP query and information about the user's browser and operating system, among other elements. An HTTP request, for any page, contains details of the browser and device making the query, such as the domain name and browser information, its type, referer, and language. Google Analytics stores and reads cookies in the user's browser to evaluate the user's session and other information about the query.

Regarding these data transfers, the contract related to the Google Analytics function ("Google Analytics Terms of Service") incorporates an appendix titled "Google Ads Data Processing Terms" (previously known as "Google Ads Data Processing Conditions"). This appendix contains standard contractual clauses governing the transfer of personal data to the United States of America under the Google Analytics service. Additionally, Google has implemented additional legal, organizational, and technical measures to regulate data transfers under the Google Analytics service. In accordance with point 10 of the "Google Ads Data Processing Terms," the data controller has agreed that Google may store and process personal data of the client (in this case, personal data of the claiming party) in any country where Google or any of its data subprocessors maintain facilities. When this information is collected, it is transmitted to the Google Analytics servers.

Returning to the document sent by Google LLC dated April 9, 2021, in the last paragraph of the response to question 8, Google states that all data collected through Google Analytics is hosted in the United States. Therefore, the data collected on the website "https://www.directseguros.es/" through Google Analytics is transferred to the United States. Such data transmission

C/ Jorge Juan, 6

www.aepd.es

requires a legal basis in accordance with Article 44 and following of the GDPR.

All these elements show that, when deciding to implement the Google Analytics function on its website, AXA SEGUROS, which manages the website "<https://www.directseguros.es/>", determined the means and purposes of the collection and processing of the data obtained as a result of the integration of Google Analytics into its website and must be considered the data controller in the sense of Article 4.7 of the GDPR.

2.- On the qualification of the data subject to processing as personal data

It can be stated that the data collected under the Google Analytics function and transferred to the United States of America constitutes personal data.

Article 4.1 of the GDPR defines personal data as "any information relating to an identified or identifiable natural person ('the data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific factors characteristic of the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person."

It should be noted that online identifiers, such as IP addresses or information stored in cookies, can commonly be used to identify a user, especially when combined with other types of similar information. This is illustrated in Recital 30 of the GDPR, which states that the assignment of online identifiers such as IP addresses, cookie identifiers to natural persons or their devices can "leave traces that, in particular when combined with unique identifiers and other information received by the servers, can be used to create profiles of natural persons and identify them." In the particular case where the data controller claims not to have the ability to identify the user through the use (alone or combined with other data points) of such identifiers, it would be expected to disclose the specific means deployed to ensure the anonymity of the collected identifiers. Without such details, they cannot be considered anonymous.

Therefore, it is necessary to examine to what extent the implementation of Google Analytics on a website allows the website administrator and Google to identify a data subject (a visitor to the website in question).

When the claimant visited the website <https://www.directseguros.es/>, the following data (via JavaScript code) were transmitted from the claimant's browser to the servers of Google LLC:

- Cookies `_ga` and `_gid`
- URL of the visited webpage (parameter `dl`) and title of the visited webpage (parameter `dt`)
- IP
- `sr` (screen resolution), among other parameters.
- Data about the browser and operating system:



Unique identifier that identifies the website operator

It should be noted that the CJEU has already stated that IP addresses are personal data (see case C-597-19, paragraph 102 and C-582/14, paragraph 49). The IP address does not lose its nature as personal data simply because the means of identification reside with third parties. Furthermore, the case in question is very different, as the IP address can be combined with other elements, as will be described below.

Regarding unique identifiers, when a user visits the website <https://www.directseguros.es/>, its cookie policy acknowledges the use of Google Analytics, which involves sending the values of the cookies

“_ga” and “_gid” to Google LLC, as stated in the reference for Google Analytics cookies (page 134 of the file).

According to the description of Google Analytics available at the URLs:

“<https://developers.google.com/analytics/devguides/collection/analyticsjs/field-reference>”

and “<https://developers.google.com/analytics/devguides/collection/gajs/cookie-usage>”,

the cookies _ga and _gid are used to distinguish users and the parameter “sr” refers to screen resolution.

Visitor identifiers are unique identifiers intended to differentiate individuals (where such differentiation was not possible before), and make individuals identifiable. These identifiers can also be combined with other information, such as the address of the visited website, metadata related to the browser and operating system, the time and data related to the website visit, and the IP address. This combination of information further differentiates individuals.

For this reason, when several elements are combined, they can allow for the individual identification of visitors to the website “<https://www.directseguros.es/>”, where Google Analytics is implemented. It is not necessary to know the name or the (physical) address of the visitor, as, according to Recital 26 of the GDPR, such qualification of individuals is sufficient for the visitor to be identifiable.

If the opposite were decided, the scope of the right to data protection, guaranteed by Article 8 of the Charter of Fundamental Rights of the European Union, would be undermined, as it would allow companies to specifically select individuals along with personal information (for example, when visiting a specific website) while simultaneously denying them any right to protection against such singling out. Such a restrictive opinion that would undermine the level of protection for individuals is also not in line with the jurisprudence of the Court of Justice of the European Union (hereinafter, CJEU), which has repeatedly ruled that the scope of the GDPR must be understood very broadly (see, for example, judgment C-439/19, paragraph 61).

Google LLC claims that it has “no intention” of using online identifiers to identify the claimant (or other individuals), as stated in the last paragraph of the response to question 13 of the document dated April 9, 2021, and that in fact “they do not do this.” It should be noted that Article 4, paragraph 1, of the GDPR does not

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/30

requires that an entity has a specific intention to identify a person.

According to the clear wording of Article 4, paragraph 1, of the GDPR, the term

“personal data” is completed when an entity can (has the possibility to) do so.

Even a more restrictive interpretation of Article 4, paragraph 1, of the GDPR, which in any case would be contrary to the jurisprudence of the CJEU, would understand the definition of “personal data” as applicable to the exposed data. In the event that any visitor to the website <https://www.directseguros.es/> had logged into a

Google account at the time of their visit, as can be seen in the statement from Google LLC dated April 9, 2021, the implementation of Google Analytics on a website allows Google to receive information that a specific user of the Google account has visited that website.

In the context of the use of Google Analytics, and depending on some settings in the Google user account configuration (see response to question 9 of Google’s document dated April 9, 2021), it allows Google to receive information that a user connected to a Google account has visited a particular website. Therefore, personal data related to this account is collected. For all these reasons, it must be considered that the data in question are personal data in the sense of Article 4.1 of the GDPR.

3.- On the breach of the obligation to regulate the transfer of personal data outside the European Union

In this case, it must be verified whether the export of personal data to the

United States of America occurred as indicated by the claimant, in the terms set forth in Article 44 of the GDPR, and, in the event that it occurred, whether the export was carried out with an adequate level of protection in accordance with an adequacy decision under Article 45 of the GDPR, or, failing that, whether any of the guarantees under Article 46 of the GDPR were adopted.

□

Adequacy decisions

In its judgment in case C-311/18 ("Schrems II"), dated July 16, 2020, the CJEU invalidated the Commission's Implementing Decision (EU) 2016/1250 of July 12, 2016, pursuant to Directive 95/46/EC of the European Parliament and of the Council, on the adequacy of the protection provided by the "EU-US Privacy Shield", without maintaining its effects on the date of the facts subject to the claim.

In the absence of an adequacy decision applicable to the present case, the transfer of the data in question cannot be based on the provisions of Article 45.3 of the GDPR.

□

Appropriate safeguards: Standard contractual clauses

Article 46, "Transfers subject to appropriate safeguards," of the GDPR, establishes in its paragraph 1 that "In the absence of a decision under Article 45, paragraph 3, the controller or the processor may only transmit personal data to

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/30

a third country or international organization if adequate guarantees have been offered and provided that the data subjects have enforceable rights and effective legal remedies."

Article 46, paragraph 2, of the GDPR states that "The adequate guarantees referred to in paragraph 1 may be provided, without requiring any express authorization from a supervisory authority, by:

(...)

c) standard data protection clauses adopted by the Commission in accordance with the examination procedure referred to in Article 93, paragraph 2.

(...)."

The standard contractual clauses of Google for the transfer of personal data to the United States, updated on September 27, 2021, under the name "Google Ads & Measurement: Standard Contractual Clauses (Module 3: Processor-to-Processor)," which could be translated as: "Google Ads Data Processing Terms: Standard Contractual Clauses, Standard Contractual Clauses Processor to Processor" (hereinafter, SCC). These clauses comply with those published by the European Commission in Decision 2010/87/EU.

In this context, it is noteworthy that standard contractual clauses are a transfer instrument in the sense of Chapter V of the Regulation and were not challenged as such by the CJEU in its judgment of July 16, 2020 (C-311/18). However, the CJEU considered that the contractual nature of these clauses implied that they could not be binding on the authorities of third countries. In particular, the CJEU stated that: "...Therefore, while there are situations in which, depending on the legislation and practices in force in the third country in question, the recipient of such a transfer is in a position to guarantee the necessary protection of the data solely on the basis of standard data protection clauses, there are others in which the content of such standard clauses may not constitute a sufficient means to ensure, in practice, the effective protection of the personal data transferred to the third country in question. This is particularly the case when the legislation of that third country allows its public authorities to interfere with the rights of the data subjects to whom the data relates" (C-311/18, paragraph 126, emphasis added).

No further analysis of the legal situation in the United States is necessary, as the CJEU has already provided it in its aforementioned judgment. Indeed, the CJEU considered that regulatory surveillance programs such as Section 702 of FISA and E.O. 12333 in conjunction with PPD-28 do not meet the

minimum requirements established by Union law regarding the principle of proportionality, so that surveillance programs based on these provisions cannot be considered limited to what is strictly necessary (C-311/18, paragraph 184). Furthermore, the CJEU found that the legal framework in question did not confer on data subjects rights that are actionable before the courts against U.S. authorities, from which it follows that these individuals do not have the right to effective judicial protection (C-311/18, paragraph 192).

The CJEU's analysis is relevant in the present case, as Google LLC (as the importer of the data to the U.S.) must be classified as a service provider.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
23/30

of electronic communications in the sense of paragraph (b) of point 4 of Article 1881 of Title 50 of the United States Code and, therefore, is subject to surveillance by U.S. intelligence services in accordance with paragraph (a) of Article 1881 of Title 50 of the United States Code ("FISA 702"). Therefore, Google LLC has the obligation to provide personal data to the government of the United States when requested in accordance with paragraph (a) of Article 1881 of Title 50 of the United States Code (FISA 702). As can be seen in Google's Transparency Report, Google LLC is regularly subject to such access requests from U.S. intelligence services. The report can be consulted at:

<https://transparencyreport.google.com/user-data/us-national-security?hl=en>

The CJEU stated, on the one hand, that the EU-U.S. adequacy decision was invalid due to the access possibilities of U.S. intelligence services and, on the other hand, concluded that the use of standard contractual clauses cannot, by itself, guarantee a level of protection as required by Article 44 of the GDPR, since the guarantees they offer are unmet when such access requests are made. In fact, the CJEU concluded the following:

"It follows that the standard data protection clauses adopted by the Commission on the basis of Article 46(2)(c) of the GDPR are intended solely to provide contractual guarantees that apply uniformly in all third countries to controllers and processors established in the European Union and, consequently, regardless of the level of protection guaranteed in each third country. Insofar as these standard data protection clauses cannot, by their very nature, offer guarantees beyond a contractual obligation to ensure compliance with the level of protection required by Union law, they may require, depending on the prevailing situation in a specific third country, the adoption of supplementary measures by the controller to ensure compliance with that level of protection" (C-311/18, paragraph 133).

•

General observations on supplementary measures

In its Recommendations 01/2020, dated June 18, 2021, (which can be consulted at the website https://edpb.europa.eu/system/files/2021-06/edpb_recommendations_202001vo.2.0_supplementarymeasurestransferstools_en.pdf, although the transcripts included in this document refer to its translation into Spanish) the European Data Protection Board (EDPB) has clarified that when the assessment of the legislation or practices in force in the third country may affect the effectiveness of the adequate safeguards of the transfer instruments on which the exporter relies, in the context of its specific transfer, as is the case here following the CJEU's assessment, the exporter must suspend the transfer or implement appropriate supplementary measures. The EDPB notes in this regard that "Any supplementary measure can only be considered effective in the sense of the CJEU ruling 'Schrems II' to the extent that it addresses the specific deficiencies identified in its assessment of the legal situation in the third country. If, ultimately, it cannot ensure a level of protection essentially equivalent, personal data should not be transferred."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
24/30

(see Recommendations 01/2020, point 75).

The measures to complement the standard clauses for data protection can be classified into three categories: contractual, technical, or organizational (see Recommendations 01/2020, point 74).

Regarding contractual measures, the EDPB stated that: "In some situations, these measures may complement and reinforce the guarantees that the transfer instrument and the relevant law of the third country may provide when, considering the circumstances of the transfer, they do not meet all the necessary conditions to ensure a level of protection essentially equivalent to that guaranteed in the Union. Given the nature of contractual measures, which generally cannot bind the authorities of that third country when they are not part of the contract, these must be combined with other technical and organizational measures to provide the required level of data protection (...)" (see Recommendations 01/2020, point 99, emphasis added).

As for organizational measures, the EDPB highlighted that: "...Selecting and applying one or more of these measures will not necessarily and systematically guarantee that your transfer complies with the essential equivalence standard required by Union law. Depending on the specific circumstances of the transfer and the assessment carried out on the law of the third country, organizational measures will be needed to complement the contractual or technical measures, in order to ensure a level of protection of personal data essentially equivalent to that guaranteed in the Union" (see Recommendations 01/2020, point 128, emphasis added).

Regarding technical measures, the EDPB noted that "...These measures will be especially necessary when the legislation of that country imposes obligations on data importers that are contrary to the guarantees of Article 46 of the GDPR and may, in particular, affect the contractual guarantee of an essentially equivalent level of protection against access by public authorities of that third country to such data" (see Recommendations 01/2020, point 77). It added that "The measures listed below aim to ensure that access by public authorities of third countries to the transferred data does not affect the effectiveness of the appropriate safeguards contained in the transfer instruments of Article 46 of the GDPR. These measures apply even if access by public authorities complies with the law of the importing country, when such access goes beyond what is necessary and proportionate in a democratic society. These measures aim to prevent the possible breach of access by preventing authorities from identifying data subjects, inferring information about them, individualizing them in another context, or associating the transferred data with other datasets they may possess that may contain, among other data, online identifiers provided by the devices, applications, tools, and protocols used by data subjects in other contexts." (see Recommendations 01/2020, point 79, emphasis added).

□

Complementary measures implemented by Google LLC

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/30

Google LLC, as the data recipient of users of its Google Analytics services, has adopted contractual, organizational, and technical measures to complement the SCC. In the document dated April 9, 2021, sent by Google LLC to the Austrian data protection authority, which it shared with the other authorities within the framework of the TF101 Working Group, Google LLC described the measures taken in detail.

Considering the considerations of the CJEU and the EDPB, it must now be verified whether the complementary measures adopted by Google LLC were effective, meaning that they address the specific issue of the access possibilities of U.S. intelligence services.

Regarding the "legal and organizational measures" adopted, it should be noted that neither user notification, even if such notification is admissible, nor the publication of a transparency report or a "public policy on the handling of government requests" actually prevents or reduces the access possibilities of U.S. intelligence services. Furthermore, it is unclear how the "careful review of each request" by Google LLC regarding its admissibility is effective as a complementary measure, considering that, according to the CJEU, admissible (legal) requests from U.S. intelligence services do

not comply with the requirements of European Data Protection legislation.

With respect to the "technical measures" adopted, it should be noted that it has not been clarified how the described measures, such as the protection of communications between Google services, the protection of data in transit between data centers, the protection of communications between users and websites, or "site security," actually prevent or reduce the access possibilities of U.S. intelligence services based on the legal framework of the United States.

Regarding encryption technologies, such as in the case of "data at rest" in data centers, as specifically mentioned by Google LLC as a technical measure, it should be noted that Google LLC, as a data importer, has the obligation to grant access or deliver personal data imported under its control, including the cryptographic keys necessary for the data to be intelligible (see Recommendations 01/2020, point 81). In other words: as long as Google LLC has the ability to access the data of individuals in clear text, this technical measure cannot be considered effective in the present case.

As Google LLC states that "to the extent that the Google Analytics data for measurement transferred by website owners are personal data, they should be considered as pseudonymous," it should be noted that universally unique identifiers (UUIDs) do not fall within the definition of Article 4.5 of the GDPR. While pseudonymization can be a privacy-enhancing technique, unique identifiers have, as previously described, the specific intention of identifying users, not acting as a safeguard. Apart from this, it has also been previously described why the combination of unique identifiers with other elements (such as browser or device data and the

26/30

IP address) and the possibility of linking such information to a Google account in any case allows for the identification of a person.

Insofar as Google LLC refers to a "technical optional measure" through an IP anonymization feature, it should be noted, first of all, that this measure is, as its name indicates, optional and not applicable to all transfers. Furthermore, from Google's response, it is not clear whether this anonymization occurs prior to the transfer or if the full IP address is transmitted to the United States and only shortened after this transfer to the United States. Therefore, from a technical standpoint, there is potential access to the entire full IP address before it is shortened.

Consequently, the supplementary measures adopted, as presented by Google, are ineffective in that none of them address the specific issues in the present case, meaning that none of them prevent the possibilities of access by U.S. intelligence services nor render such access ineffective.

□

The exceptions provided in Chapter V of the Regulation

Article 49, "Exceptions for specific situations," of the GDPR states:

"1. In the absence of an adequacy decision pursuant to Article 45(3), or of appropriate safeguards pursuant to Article 46, including binding corporate rules, a transfer or a set of transfers of personal data to a third country or international organization may only take place if one of the following conditions is met:

a) the data subject has explicitly consented to the proposed transfer, after having been informed of the possible risks to him or her of such transfers due to the absence of an adequacy decision and appropriate safeguards;

b) the transfer is necessary for the performance of a contract between the data subject and the controller or for the implementation of pre-contractual measures taken at the request of the data subject;

(...)"

The European Data Protection Board (EDPB), in compliance with the objective of ensuring the consistent application of the General Data Protection Regulation, as attributed to it by Article 70 of the GDPR, issued Guidelines 2/2018 on the exceptions provided for in Article 49 of Regulation 2016/679. Regarding the interpretation of the condition a) of Article 49 of the GDPR (paragraph 2.1 of Guidelines 2/2018), the EDPB states that consent must be specific and informed about the possible risks, establishing the following: "this provision requires that data subjects are also informed of the specific risks arising from the fact that their data will be transferred to a country that does not provide an adequate level of protection and that no appropriate safeguards are foreseen for the protection of the

data.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
27/30

In the present case, the users' consent for the storage of cookies during their visit to the website cannot be considered equivalent to having explicitly consented to the international transfer of data, as required by Article 49.1.a) of the GDPR; this consent must be obtained specifically, and for it to be valid, AXA SEGUROS should have previously informed the data subjects of the risks associated with data transfers to the U.S., given the absence of an adequacy decision and appropriate safeguards in the sense of Article 49, paragraph 1 of the Regulation.

Regarding the possible existence of a contractual relationship, this assumption is not present, considering that Recital 111 of the GDPR requires that international data transfers based on explicit consent must be "occasional and necessary in relation to a contract," whereas in this case, the transfers occur continuously and systematically, and their necessity is not justified.

□

Current legal framework

On July 10, 2023, the Commission approved the Implementing Decision (EU) 2023/1795 regarding the adequacy of the level of protection of personal data in the EU-U.S. Data Privacy Framework under Regulation (EU) 2016/679 of the European Parliament and of the Council, so that international transfers made after this date may be covered by the aforementioned Decision.

On the website <https://www.dataprivacyframework.gov/s/>, it can be verified that Google LLC has certified its adherence to the principles of the Data Privacy Framework until September 13, 2024, due to the need to renew this certification annually. Therefore, currently, international data transfers to Google LLC in the U.S. are covered by the EU-U.S. Data Privacy Framework.

However, it must be concluded that, on the date when the events subject to the complaint occurred, AXA SEGUROS cannot invoke any of the tools provided for in Chapter V of the GDPR to justify the international transfers of personal data of visitors to its website, particularly unique identifiers, IP addresses, browser data, and metadata, to Google LLC in the United States, fully applying the doctrine established by the Court of Justice of the European Union in the ruling of the Schrems II case, which invalidated the decision on the "EU-U.S. Privacy Shield."

Consequently, in accordance with the evidence available in this warning procedure resolution, it is considered that the known facts constitute an infringement attributable to AXA SEGUROS for violation of Article 44, "General principle for transfers," of the GDPR, which states that personal data that is subject to processing or will be processed after its transfer to a third country or international organization may only be transferred if, subject to the other provisions of the GDPR, the controller and the processor comply with the conditions established in this chapter, including those relating to further transfers of personal data from the third country or international organization to another third country or another international organization.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

28/30

Classification and qualification of the infringement of Article 44 of the GDPR

The violation of Article 44 of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to 4% of the total annual global turnover of the

preceding financial year, opting for the higher amount:

(...)

c) the transfers of personal data to a recipient in a third country or an international organization pursuant to Articles 44 to 49;

(...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements," establishes that "Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 72 "Very serious infringements" of the LOPDGDD indicates:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements shall be considered very serious and shall be subject to a limitation period of three years, which involve a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

l) The international transfer of personal data to a recipient located in a third country or to an international organization when the guarantees, requirements, or exceptions established in Articles 44 to 49 of Regulation (EU) 2016/679 are not present. (...)"

VI

Warning

Article 64 of the LOPDGDD, which regulates the "Initiation of the procedure and duration," in its third paragraph provides that:

"3. When appropriate, considering the nature of the facts and duly taking into account the criteria established in Article 83.2 of the Regulation, ..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/30

(UE) 2016/679 of the European Parliament and of the Council, of April 27, 2016, the Spanish Agency for Data Protection, after hearing the data controller or processor, may issue a warning, as well as order the data controller or processor to adopt corrective measures aimed at ending the possible non-compliance with data protection legislation in a specific manner and within the specified timeframe.

The procedure shall have a maximum duration of six months from the date of the initiation agreement. After this period, it shall expire, and consequently, the proceedings shall be archived.

The provisions of the second and third paragraphs of section 2 of this article shall apply in this case.

In accordance with the evidence available at this moment of resolution of the procedure, the balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, for the infringement committed by violating the provisions of Article 44 of the GDPR, it is appropriate to issue a warning to AXA SEGUROS.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO ISSUE A WARNING to AXA SEGUROS GENERALES, S.A. DE SEGUROS Y REASEGUROS, with NIF A60917978, for an infringement of Article 44 of the GDPR, classified under Article 83.5 of the GDPR.

SECOND: TO NOTIFY this resolution to AXA SEGUROS GENERALES, S.A. DE SEGUROS Y REASEGUROS.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6

of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Administrative Contentious Chamber of the National Court, in accordance with the provisions of Article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Administrative Contentious Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency is not aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension to be concluded.

1403-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es